

Open source на страже Kubernetes Runtime Security

Анатолий Карпенко

Luntry

whoami

- Автоматизатор автоматизации в Luntry
- Любитель митапошных форматов; ITGM, TechTrain, DevOops, DEFCON'ы, SafeCode, БЕКОН, ТБ Форум, UDW, DUMP, CodeFest
- Веду канал «Технологический Болт Генона»
- Рисую несмешные мемы



Разработчики/QA?

Разработчики/QA?

Админы, SRE, Dev[Sec]Ops и прочие Ops'ы?

Разработчики/QA?

Админы, SRE, Dev[Sec]Ops и прочие Ops'ы?

Различного рода ИБ?

ДИСКЛЕЙМЕР

ЭТО ТЕКСТ КОТОРЫЙ НИКТО НЕ ЧИТАЕТ
ПОЭТОМУ Я ПРОГОВОРЮ ЧТО Я НЕ СМОГУ
РАССКАЗАТЬ ОБО ВСЁМ ЧЁМ ХОТЕЛОСЬ БЫ
НО ПОСТАРАЮСЬ ОТМЕТИТЬ ЧАСТЬ
ВАЖНЫХ ПУНКТОВ ДЛЯ СЛУШАТЕЛЕЙ
ОСТАЛЬНОЕ МОЖНО БУДЕТ ОБСУДИТЬ ПОСЛЕ
ДОКЛАДА ИЛИ ПОСМОТРЕТЬ ПО ССЫЛКАМ
КОТОРЫЕ Я ОСТАВЛЮ В ПРЕЗЕНТАЦИИ

"Путь самурая" (агенда)

- Статика
  - Dockerfile
  - Docker-образы
- Falco и Tetragon
- KubeArmor (+ Modelarmor)
- StackRox и NeuVector
- kube-bench
- Kyverno и OPA/Gatekeeper
- Krane

Долгий путь начинается с Dockerfile...

Dockerfile (SAST)

- Hadolint
- KICS
- Checkov
- Semgrep
- ...



https://vkvideo.ru/video-211664921_456239070

Кто что использует?

- Hadolint
- KICS
- Checkov
- Semgrep
- ...

Пример KICS

```
$ kics scan -p Dockerfile
. . .
Last User Is 'root', Severity: HIGH, Results: 1

        [1]: ../../path/Dockerfile:50

                049:
                050: USER root
                051:
```

https://docs.kics.io/latest/queries/dockerfile-queries/67fd0c4a-68cf-46d7-8c41-bc9fba7e40ae

Пример KICS

fix(dockerfile): remove user root and add platform #7031

Merged cx-andre-peixoto merged 6 commits into master from AST-40561 on Apr 30, 2024

Conversation 1 Commits 6 Checks 0 Files changed 2

cx-rui-araujo commented on Apr 29, 2024

Closes #

Proposed Changes

- Remove user root
- Add platform to command FROM
- Change GIT image tag from 'latest' to 'latest

I submit this contribution under the Apache-2.0

update(dockerfile): revert KICS user change from 65532 back to root

Merged cx-rui-araujo merged 7 commits into master from ruiar/update-kics-image on Jan 31, 2025

Conversation 3 Commits 7 Checks 0 Files changed 6

cx-rui-araujo commented on Jan 31, 2025 • edited Contributor

Reason for Proposed Changes

- KICS always used root, but in the latest release, we changed it to 65532 due to FedRAMP policies. This change is causing issues in AST-CLI. Since we only use the binaries inside the image, there is no relevant reason to use 65532 instead of root. A possible fix is to run the KICS image with the same user as the container running it. However, since this would require users to change their setup, I am reverting this change to avoid that and to prevent other potential issues.

Proposed Changes

- revert KICS user change from 65532 back to root
- update KICS gh action to v2.1.4
- fix vulnerabilities

I submit this contribution under the Apache-2.0 license.

Reviewers
cx-artur-ribeiro
+1 more reviewer
cx-eduardo-se

Assignees
cx-rui-araujo

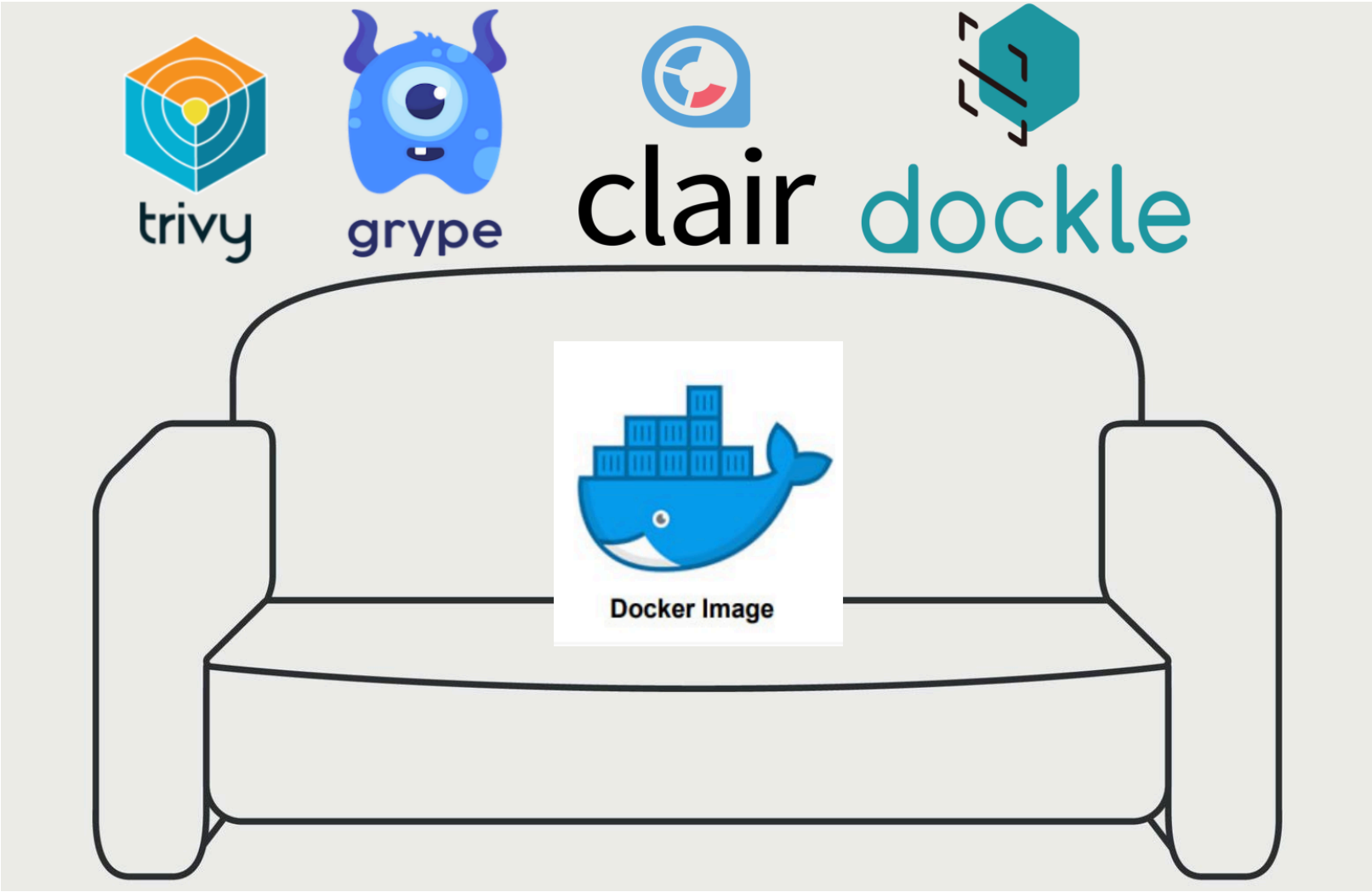
Labels
dockerfile

Projects
None yet

#7031,#7322, The Federal Risk and Authorization Management Program(FedRAMP)

Images

- Trivy
- Grype
- Clair
- Dockle
- ...



Кто что использует?

- Trivy
- Grype
- Clair
- Dockle
- ...

Trivy, Grype (example)

```
$ grype tomcat:10.1.54-jre17 --sort-by risk | grep java
...
tomcat-coyote 10.1.54 10.1.55 java-archive  GHSA-r29c-68gh-xp6x Critical 1.7% (76th) 1.6
```

```
$ trivy image -f json tomcat:10.1.54-jre17    | jq -r '.Results[].
Vulnerabilities[]? | [.PkgName, .VulnerabilityID, .Severity, .FixedVersion]
| @tsv' | column -t -s$'\t' | grep apache
...
org.apache.tomcat:tomcat-catalina  CVE-2026-43512  CRITICAL  9.0.118, 10.1.55, 11.0.22
org.apache.tomcat:tomcat-catalina  CVE-2026-43515  CRITICAL  9.0.118, 10.1.55, 11.0.22
org.apache.tomcat:tomcat-catalina  CVE-2026-65182  CRITICAL  11.0.25, 10.1.58, 9.0.121
org.apache.tomcat:tomcat-catalina  CVE-2026-65905  CRITICAL  11.0.25, 10.1.58, 9.0.121
org.apache.tomcat:tomcat-catalina  CVE-2026-68525  CRITICAL  11.0.25, 10.1.58, 9.0.121
org.apache.tomcat:tomcat-catalina  CVE-2026-41284  HIGH      9.0.118, 10.1.55, 11.0.22
org.apache.tomcat:tomcat-catalina  CVE-2026-42498  HIGH      9.0.118, 10.1.55, 11.0.22
org.apache.tomcat:tomcat-catalina  CVE-2026-43513  HIGH      9.0.118, 10.1.55, 11.0.22
org.apache.tomcat:tomcat-catalina  CVE-2026-43514  LOW       9.0.118, 10.1.55, 11.0.22
org.apache.tomcat:tomcat-coyote    CVE-2026-41293  CRITICAL  9.0.118, 10.1.55, 11.0.22
```

https://trivy.dev/docs/latest/coverage/language/java/#jarwarparear

Demo (Trivy)

Trivy (Расследование)



afdesk commented on Mar 14, 2023 — Contributor

> shouldn't the file `test.txt` containing the `AWS_ACCESS_KEY_ID` still be detected by `trivy image IMAGE --debug --scanners secret`?

yes, sure. you're right. Trivy has to detect secrets inside files, and Trivy does it)
but Trivy skips test data...

if you change a file name (eg. to `tst.txt`), Trivy will catch it:

```
FROM nginx:alpine
```

https://github.com/aquasecurity/trivy/issues/3778#issuecomment-1467988262

Trivy (Allow rules)

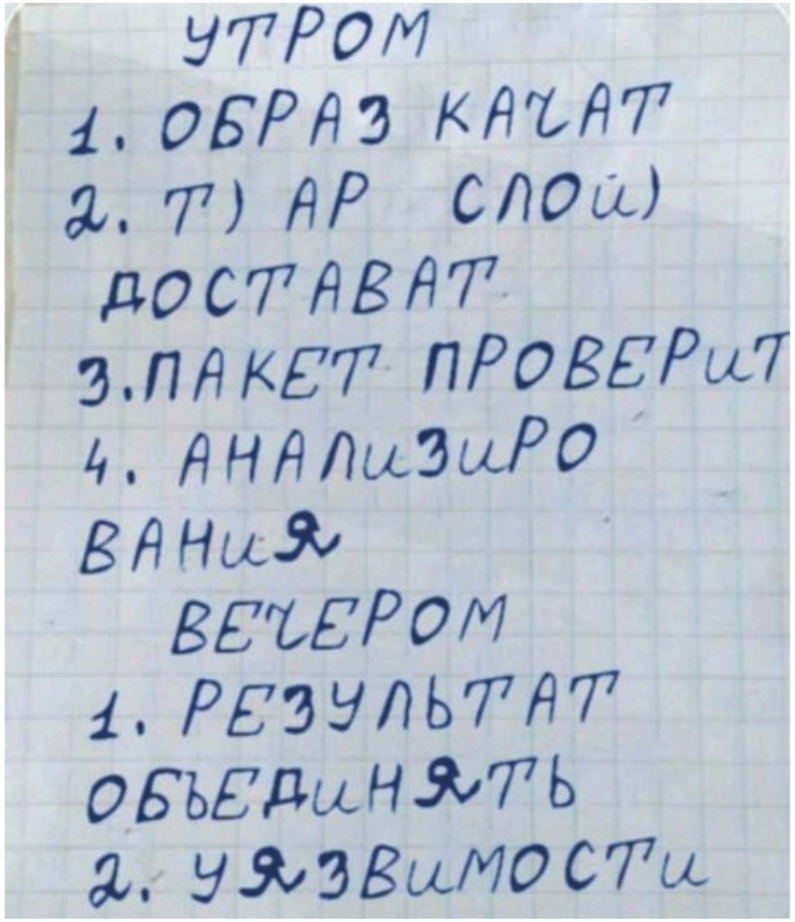
```
{
  ID:          "tests",
  Description: "Avoid test files and paths",
  Path:        MustCompile(`(^(?i)test|\/test|-test|_test|\.test)`),
},
{
  ID:          "examples",
  Description: "Avoid example files and paths",
  Path:        MustCompile(`example`),
  Regex:       MustCompile("(?i)example"),
},
```

https://github.com/aquasecurity/trivy/blob/main/pkg/fanal/secret/builtin-allow-rules.go

DUMP 2026 - «Что в образе тебе моём?»

Как работают сканеры образов

- Скачивается образ
- Послойный анализ
  - Извлечение tar-ов
  - Проверка путей пакетов
  - ...
- Объединение результатов анализа
- Сканирование на уязвимости

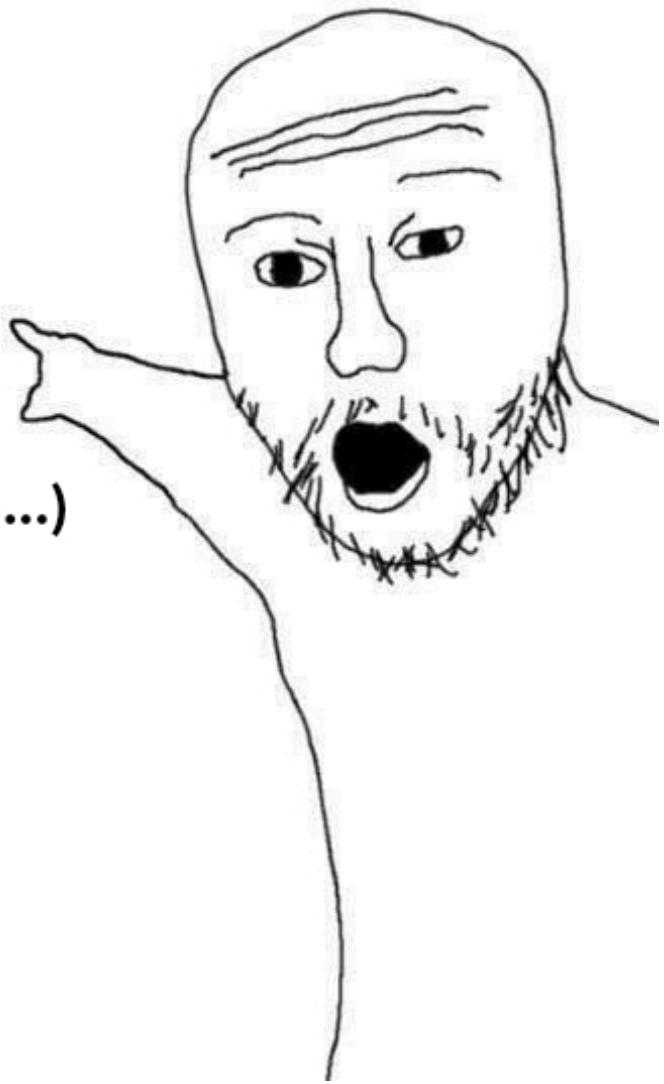


https://www.youtube.com/watch?v=73RgoyJWplY

Да это же база

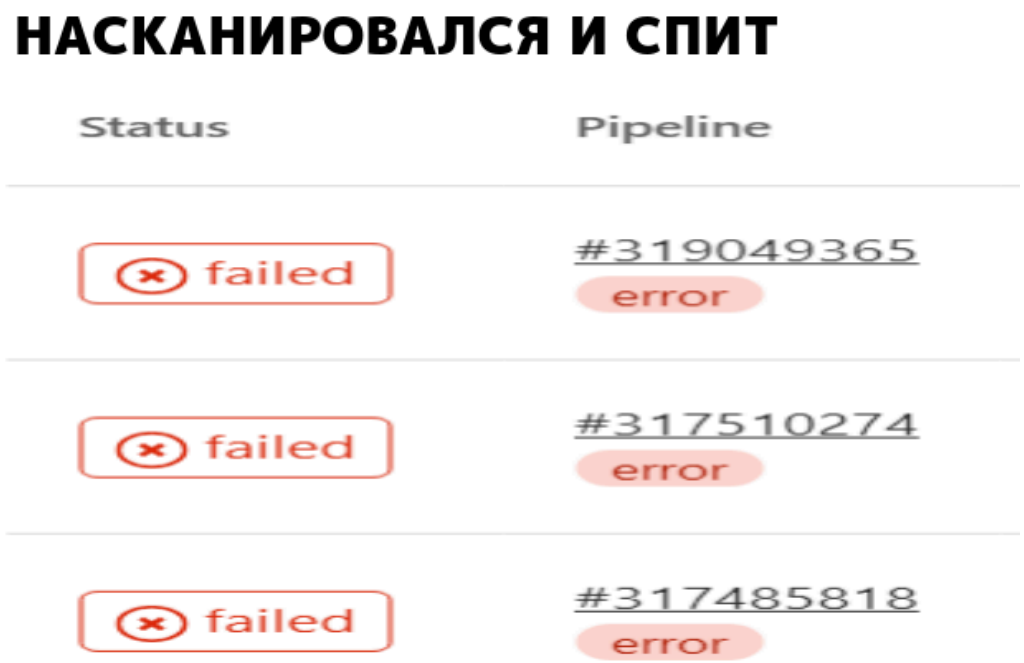


- На уровне Dockerfile (мисконфигурации)
  - Модификация слоёв
- На уровне слоев образа
  - Неисполняемые файлы (секреты, пароли...)
    - docker-squash
  - Исполняемые файлы
    - Минималистичный базовый образ
- На уровне кода
  - Известные уязвимости (CVE)
    - Минималистичный базовый образ
    - Последние версии библиотек



Что дальше?

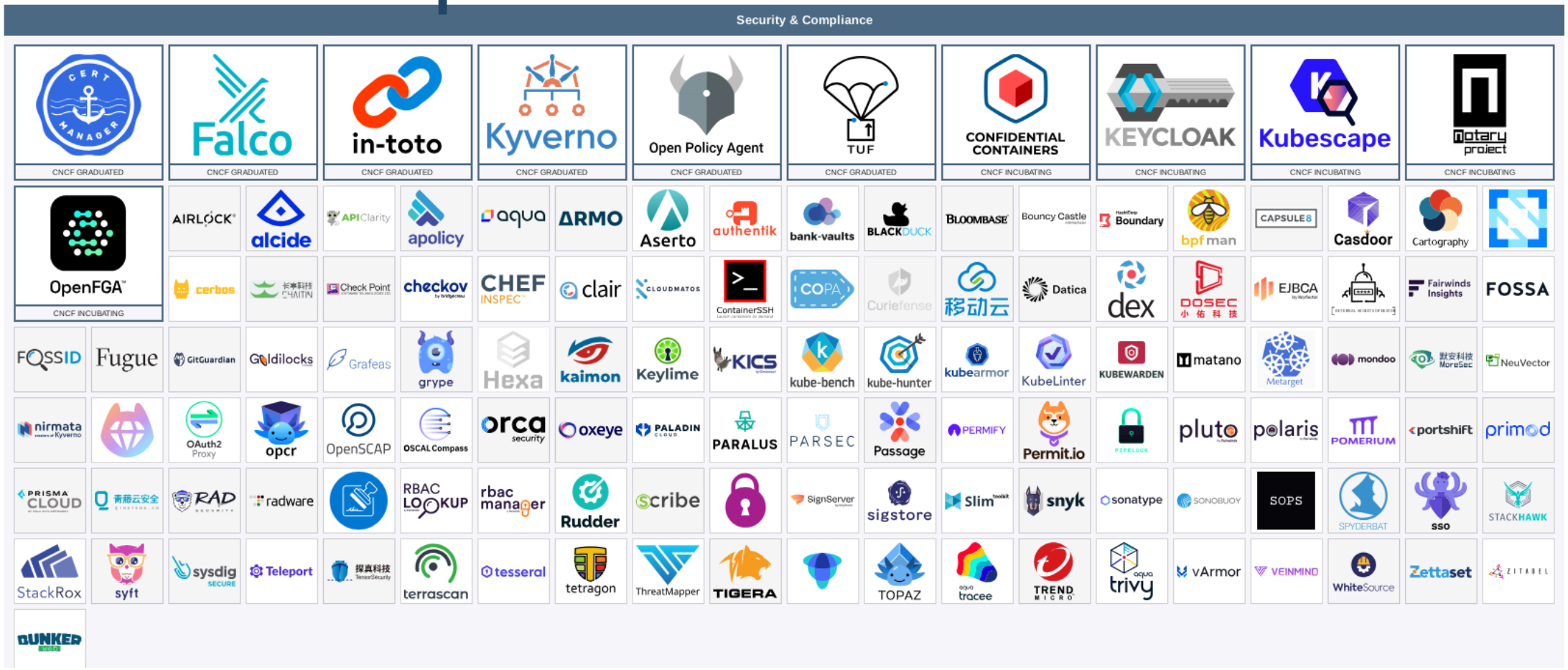
- Посканировали
- Положили в registry
- Всё проверили в registry
- Написали Helm
- Организовали hardening
- . . .
- PROFIT !11!!1 (**Едем в прод**)



Едем в Kubernetes

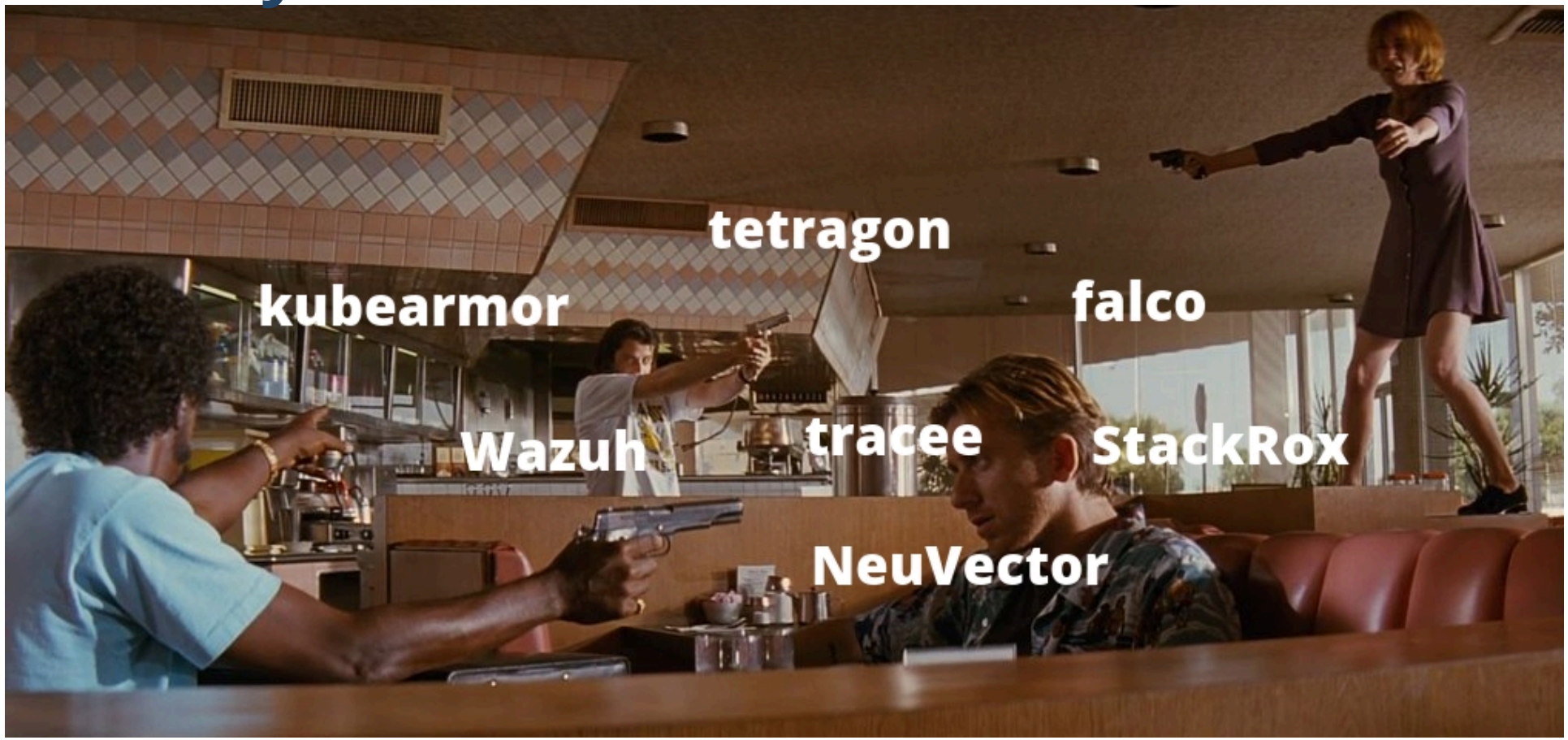


CNCF Landscape



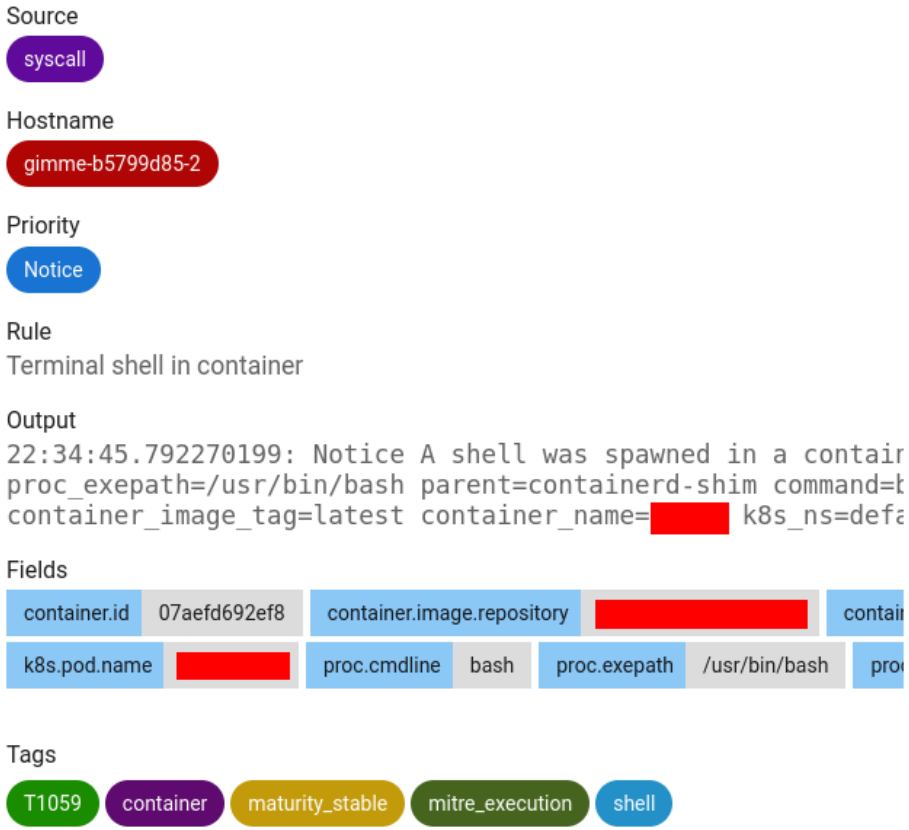
https://landscape.cncf.io/

Community <3


tetragon
kubearmor
falco
Wazuh
tracee
StackRox
NeuVector

Falco

- Мониторинг событий
- Обнаружения аномалий и угроз в реальном времени
- eBPF (syscalls для легаси)
- Реакция через сторонние "движки"
- **Большая библиотека политик**
- **Куча интеграций**
- Поддерживает плагины для разных систем (AWS CloudTrail, Kubernetes Audit Events...)
- Falco Talon



https://github.com/falcosecurity/falco

Falco (CVE-2026-31431, "copy fail")

```
- list: known_af_alg_binaries
    items: [cryptsetup, "systemd-cryptse", "systemd-cryptsetup", veritysetup,
         integritysetup, "cryptsetup-resh", kcapi-enc, kcapi-dgst, kcapi-rng, kcapi-sym]

  - macro: successful_af_alg_socket
    condition: >
      evt.type = socket and
      evt.rawres >= 0 and
      (evt.arg.domain contains AF_ALG or evt.rawarg.domain = 38)
  - macro: successful_af_alg_seqpacket_socket
    condition: >
      successful_af_alg_socket and
      (evt.arg.type = 5 or
       evt.arg.type = 2053 or
       evt.arg.type = 524293 or
       evt.arg.type = 526341)
- rule: Unexpected Process Using Kernel AEAD Crypto Socket
  desc: ...
  condition: >
    successful_af_alg_seqpacket_socket and
    not proc.name in (known_af_alg_binaries)
  output: ...
  priority: CRITICAL
```

tetragon

- Мониторинг событий
- Обнаружения аномалий и угроз в реальном времени
- eBPF
- **Умеет блокировать в режиме "реального" времени**
- Работает без CNI Cilium (но с ним лучше)
- Библиотека "политик" (отличается от Falco)
- Меньше интеграций

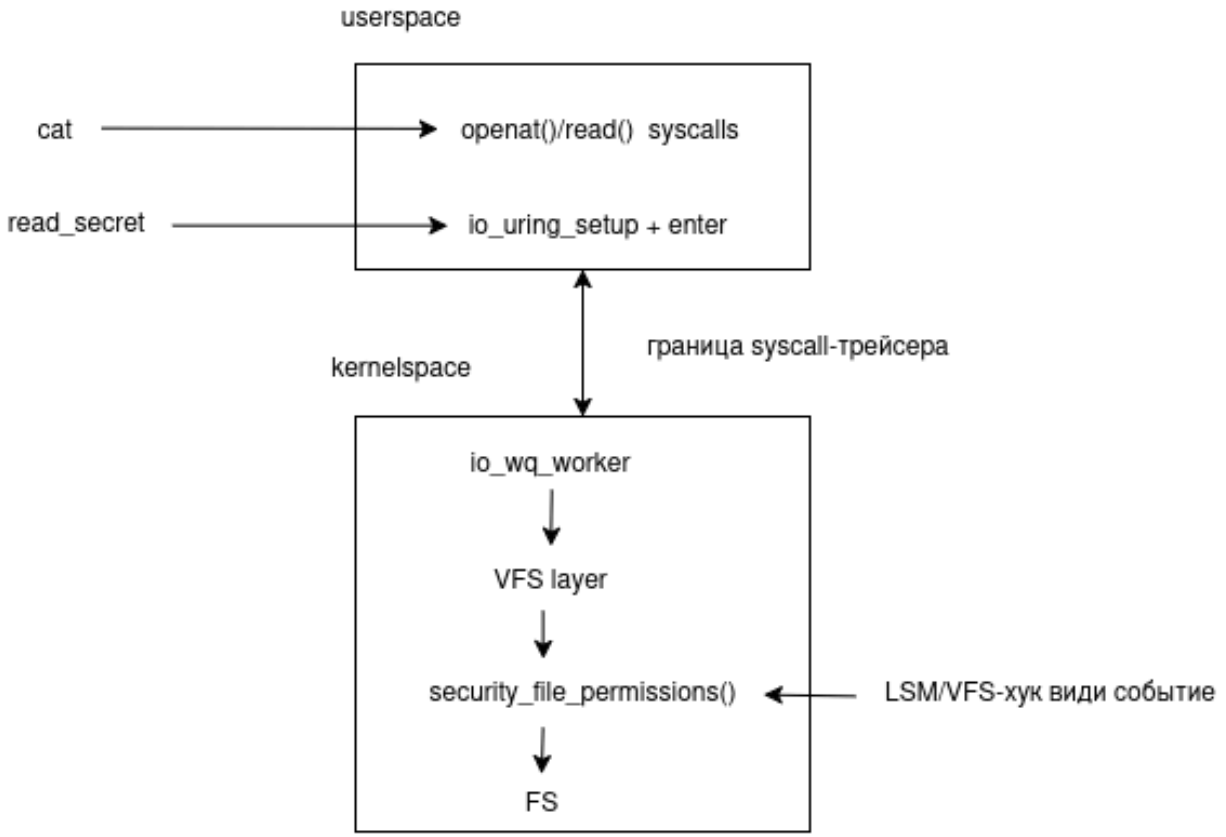
https://github.com/cilium/tetragon

Кто-то использует Falco или tetragon?

Demo

Falco+Tetragon (Расследование)

- Falco видит факт использования `io_uring` через `io_uring_setup, io_uring_enter, io_uring_register`
- Falco не видит, что именно делается через ring, так как operations лежат в shared memory, syscall-границу не пересекают
- Чтобы увидеть событие цепляемся к VFS/LSM-уровню (Tetragon с правильной политикой, KubeArmor и т.д.)



https://www.infoq.com/news/2025/09/linux-security-rootkit/

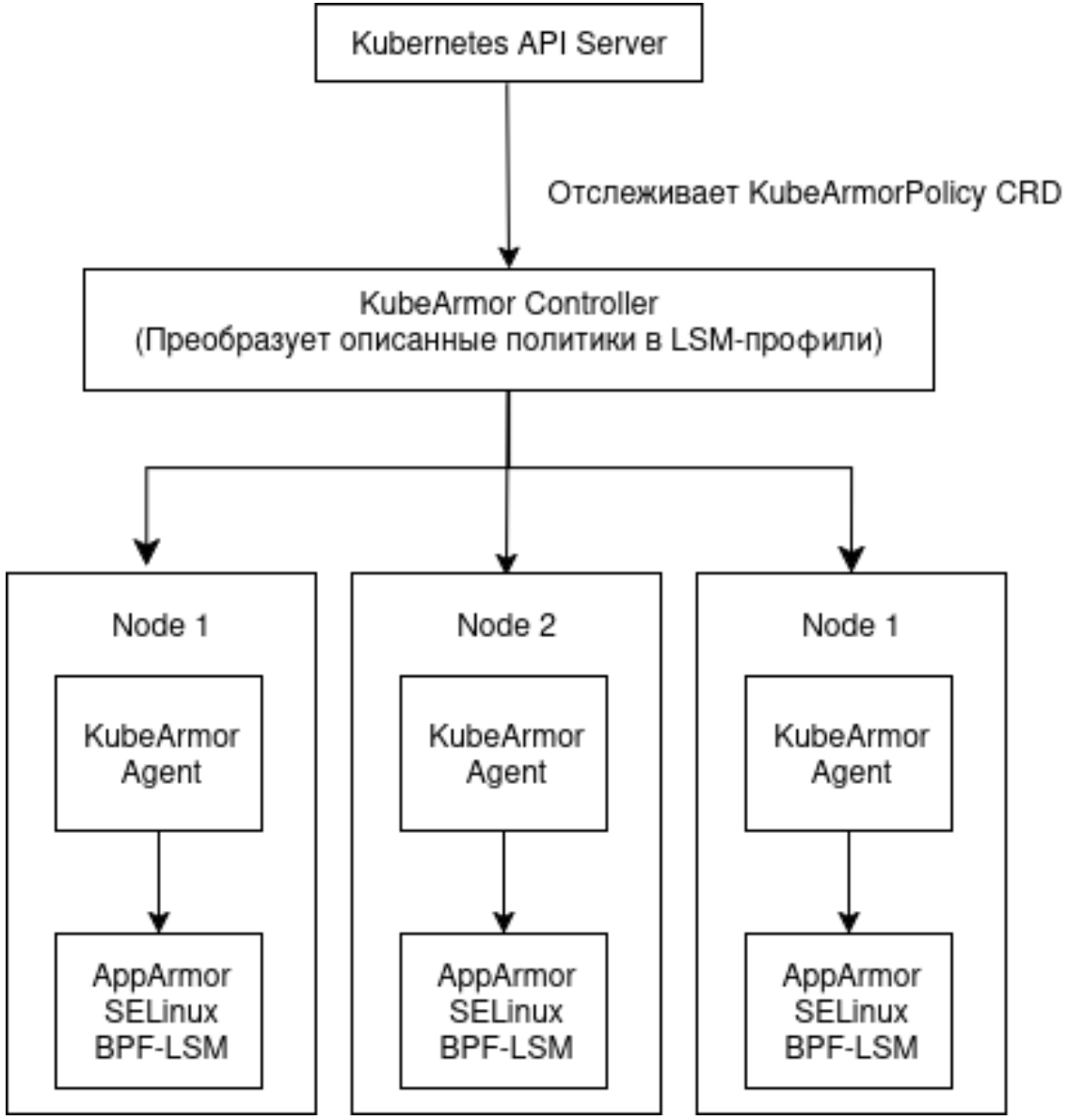
Falco vs Tetragon

Параметр	Falco	Tetragon
Реакция на угрозу	Цепочка: userspace -> webhook -> действие. Десятки-сотни мс, по факту **постфактум**	`Sigkill` / `Override` в ядре. `Override` предотвращает **в моменте**; `Sigkill` - уже после
Потеря событий	Все события в userspace; при перегрузке ring buffer переполняется, события теряются	Фильтрация **в ядре** до вывода, значит поток меньше и потерь меньше
Сетевой контекст	Syscall `connect` / `accept`. Нет L7, нет корреляции с трафиком	С Cilium/Hubble: **L3/L4/L7 + process tree** в одном событии
Правила	Большая библиотека: MITRE ATT&CK, CIS, сотни community; Falcosidekick, а значит "любой" sink	Руками через `TracingPolicy`. Меньше готового, но гранулярность **до поля kernel struct**
Shell-redirect обход	Может не поймать: правило на `open()` / `write()` не всегда покрывает запись через временный файл	Хук на **VFS** (`vfs_read` / `security_file_permission`) ловит доступ независимо от обхода на уровне userspace
Источники событий	+ K8s Audit, AWS CloudTrail, Okta, GitHub - видит **control-plane и облако**	Только ядро/хост; облачных источников нет
Зрелость	CNCF **graduated**, большое комьюнити	CNCF **incubating**, моложе, хуже документация

Оба - eBPF. Falco: широкий детект и алертинг. Tetragon: глубина в ядре + инлайн-блок (с правильным хуком)

KubeArmor

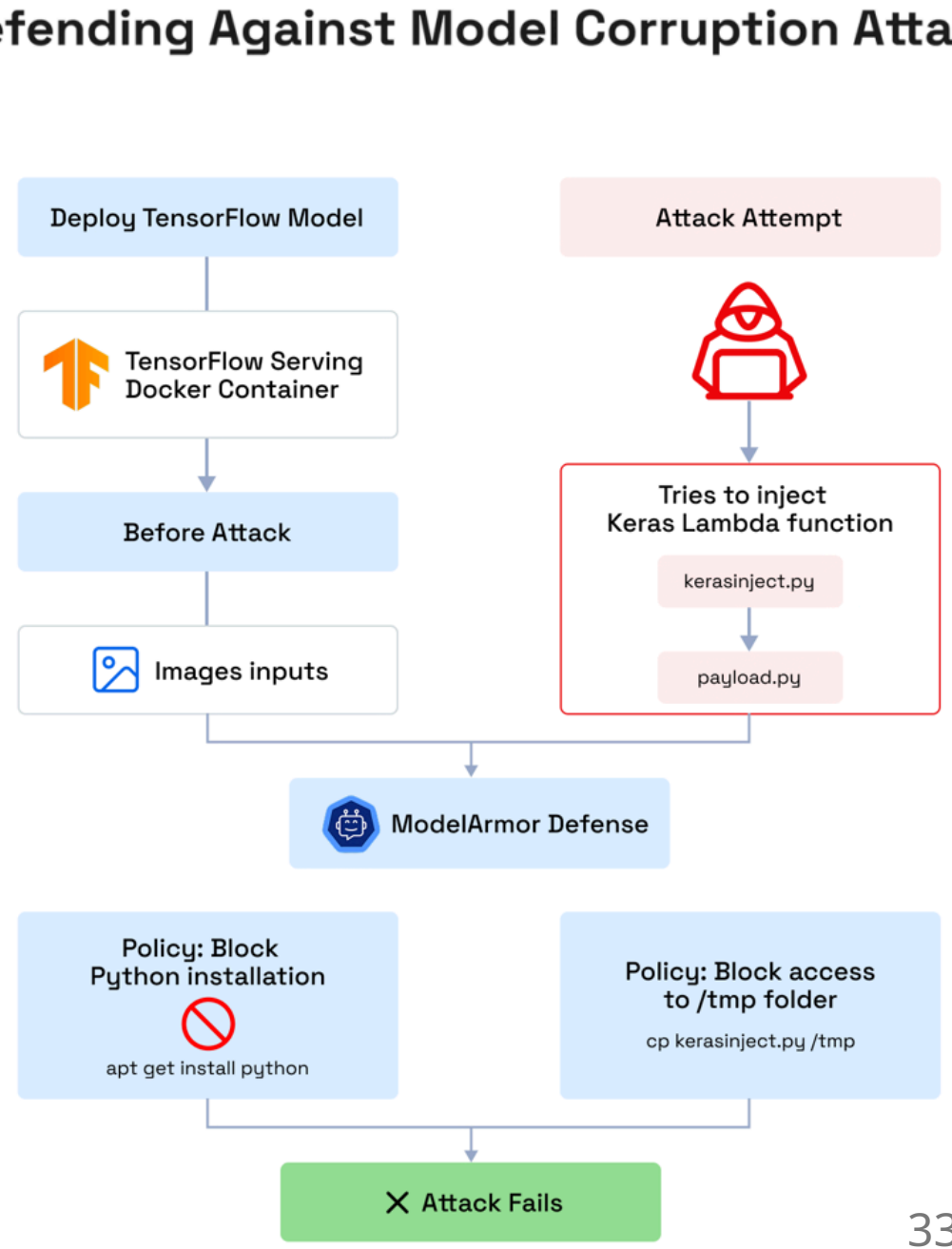
- Блокировка на уровне ядра
- Используется LSM, как основной механизм (AppArmor, SELinux, BPF-LSM)
- Есть библиотека политик
- **Не будет демо**, но в репозитории с "раздаткой" будет пример для того чтобы самостоятельно попробовать



https://github.com/kubearmor/kubearmor

Modelarmor

- Использует KubeArmor в качестве механизма песочницы для нагрузок ИИ
- Это надстройка над KubeArmor: описание проблем открыто, политики пишешь сам, а сканер и поддержка за деньги от AccuKnox
- Не путаем с **Google Cloud Model Armor**



https://github.com/kubearmor/modelarmor

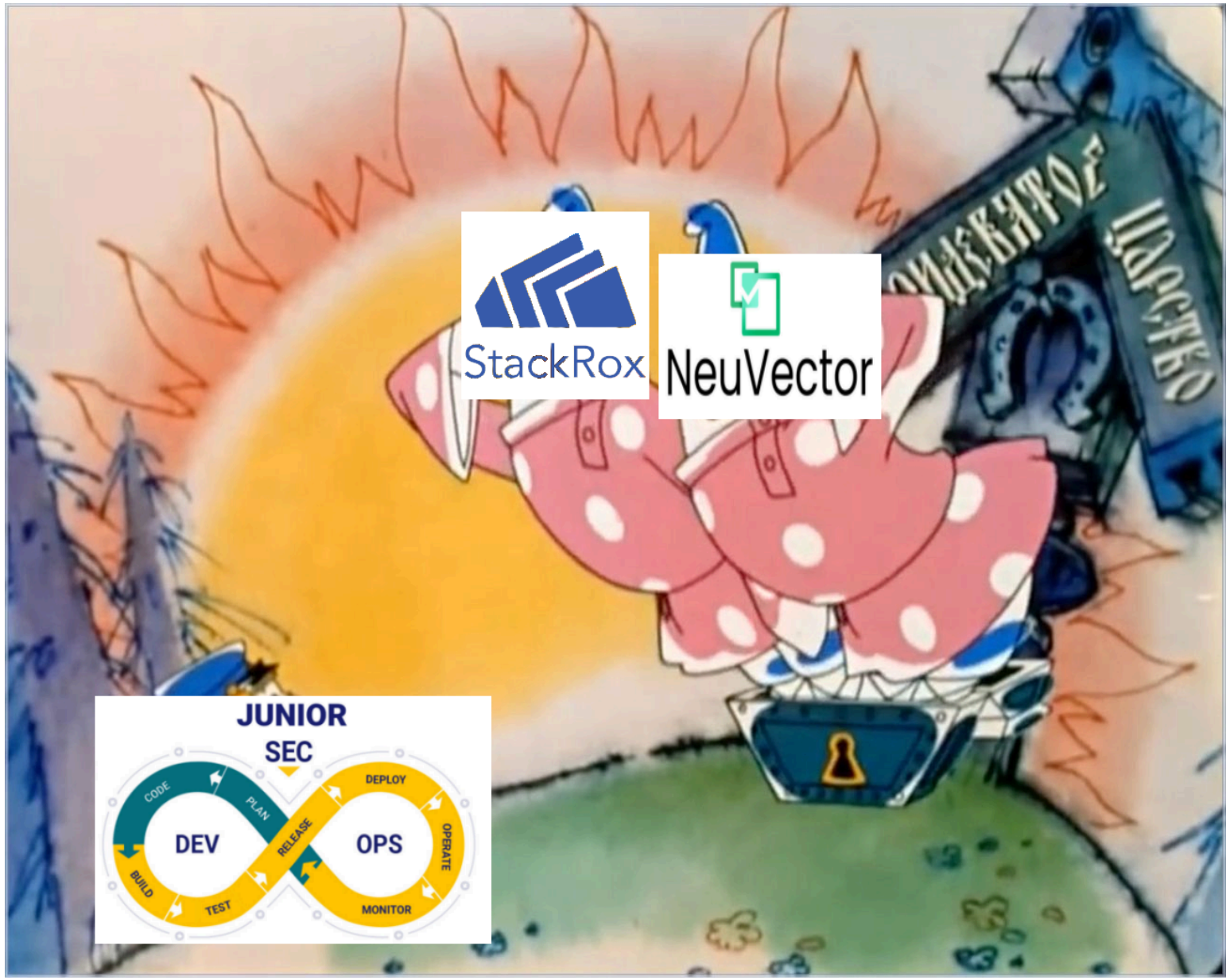
Как сделать свой "ModelArmor"?

Задача	Открытые инструменты
Изоляция AI-нагрузки в рантайме	KubeArmor, Tetragon + песочница: gVisor, Kata Containers
Скан модели на "вредонос"	ModelScan (мульти-формат) + фикс формата: safetensors
Защита промптов (инъекции, PII, джейлбрейки)	NeMo Guardrails, Llama Guard / Prompt Guard, Guardrails AI

ModelArmor ~ KubeArmor + ModelScan + Llama Guard

Кто-то использует KubeArmor?

Но это всё разрозненные инструменты...


StackRox
NeuVector
JUNIOR
SEC
DEV
OPS
CODE
PLAN
BUILD
TEST
RELEASE
DEPLOY
OPERATE
MONITOR

StackRox

- В 2021 году был поглощён RedHat (Red Hat Advanced Cluster Security for Kubernetes)
- Open source
- Features
  - Vulnerability
  - Network Graph
  - Compliance - CIS Benchmark (не обновляется RFE-5877, RFE-6049)
  - Events
  - . . .

https://github.com/stackrox/stackrox



https://vkvideo.ru/video-149053226_456239564

StackRox (examples)

CVEs by severity

- 2 Critical
- 8 Important
- 15 Moderate
- 48 Low

CVEs by status

- 2 vulnerabilities with avail
- 71 vulnerabilities without

73 results found

CVE	CVE severity	CVE status
CVE-2023-45853	Critical	Not fixable
CVE-2023-6879	Critical	Not fixable
CVE-2023-2953	Important	Not fixable
CVE-2023-31484	Important	Not fixable

Event Timeline

1	27	0	
Policy Violation	Process Activities	Restarts / Terminations	View Graph

History of Running Processes

- /nc64 in container nginx
- /usr/bin/chmod in container nginx
- /usr/bin/ls in container nginx
- /bin/bash in container nginx

NeuVector

- В 2021 году был поглощён SUSE (NeuVector Prime)
- Open source
- Features
  - Vulnerability
  - Network Graph
  - Compliance (⚠ устарел)
  - Events
  - . . .

https://github.com/neuvector/neuvector

Demo (NeuVector)

Но есть и минусы...

kube-bench

- Проверка конфигурации кластера
- Базируется на CIS Kubernetes Benchmark (стандарт де-факто)
- Master, Nodes, etcd, RBAC

```
5.2.13 Add policies to each namespace in the cluster which has user
admission of containers which use `hostPort` sections.

5.3.1 If the CNI plugin in use does not support network policies, c
making use of a different plugin, or finding an alternate mechanism
in the Kubernetes cluster.

5.3.2 audit test did not run: No tests defined
5.4.1 If possible, rewrite application code to read Secrets from mo
from environment variables.

5.4.2 Refer to the Secrets management options offered by your cloud
secrets management solution.

5.5.1 Follow the Kubernetes documentation and setup image provenanc

5.7.1 Follow the documentation and create namespaces for objects in
them.

5.7.2 Use `securityContext` to enable the docker/default seccomp pr
An example is as below:
  securityContext:
    seccompProfile:
      type: RuntimeDefault

5.7.3 Follow the Kubernetes documentation and apply SecurityContext
suggested list of SecurityContexts, you may refer to the CIS Securi
Containers.

5.7.4 audit test did not run: No tests defined

== Summary policies ==
0 checks PASS
0 checks FAIL
35 checks WARN
0 checks INFO

== Summary total ==
20 checks PASS
36 checks FAIL
60 checks WARN
15 checks INFO
```

https://github.com/aquasecurity/kube-bench

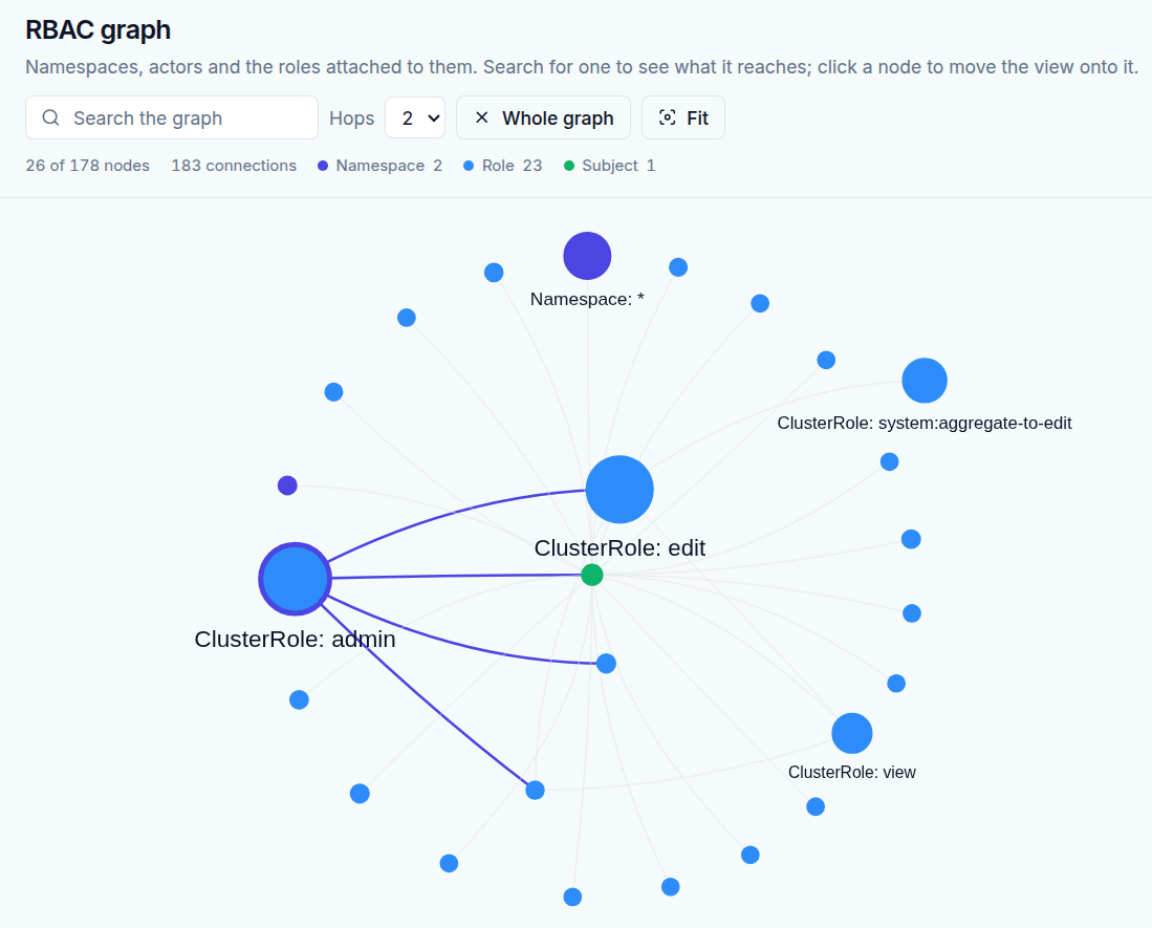
Kyverno

- Kubernetive-native policy engine
- Validate - блокировка создания ресурсов (например, запуск под root)
- Mutate - автоматически исправляет или дополняет ресурсы (например, добавление label)
- Generate - создаёт новые ресурсы (например, NetworkPolicy или ConfigMaps)
- Проверка цифровых подписей (cosign)
- Режимы блокировки или аудита
- ...
- А ещё есть OPA/Gatekeeper и не только...

https://github.com/kyverno/kyverno

Krane

- Статический анализ и визуализация RBAC в Kubernetes
- Граф связей
- Находит риски: wildcard-права, доступ к secrets, privilege escalation, опасные роли, лишние права `cluster-admin`
- Dashboard с графом + отчёт



https://github.com/appvia/krane

Вместо выводов

⚠️ Это далеко не всё. **ТЫСЯЧИ ИХ !11!!!!**

Плюсы:

- Вход бесплатен
- Блеск и нищита open source
  - Мы получаем "здесь и сейчас" решение
  - Фиксы багов
- Можно закрыть различные аспекты не дожидаясь вендораа
- Часто прозрачный Roadmap
- Нет vendor lock*

Минусы:

- Блеск и нищита open source
  - Развитие зависит от сообщества и/или владельца
  - Документация
  - Фиксы багов
- Compliance и отчетность
- Интеграция между продуктами
- Требуются усилия для получения полной картины в "едином окне"

Полезные ссылки

- Латаем огрехи в образах приложений до рантайма, во время и после
- Falco, Tetragon, KubeArmor, or Tracee? Choosing the Right Security Agent
- Hubble - Network, Service & Security Observability for Kubernetes
- Tracee - Linux Runtime Security and Forensics using eBPF
- ThreatMapper - Runtime Threat Management and Attack Path Enumeration
- Kubescape - security platform for your IDE, CI/CD pipelines, and clusters

LUNTRY

Спасибо за внимание!

site: luntry.ru

tg: @rusdacent

channel: @tech_b0lt_Genona

Вопросы?



https://github.com/rusdacent/opensource-k8s-sec